case.

At ACME, various contexts land at different points in this space. These different choices are not necessarily better or worse, as long as the trade-offs are appropriate for the use case.

- **Customers on the Customer Collaboration platform**. Customers authenticate through ACME's customer information system, which issues OAuth tokens. Signals like customer ID and basic role (viewer, collaborator) are embedded in the token. Additional context—such as account status or billing history—comes from ACME's customer database. For higher-value customers, the platform may also query an external fraud detection feed before granting access.
- **Employees on the Customer Collaboration platform.** Employees authenticate through ACME's internal identity service, not OAuth. The PDP enhances its authentication context with HR and Finance data via internal APIs. Device posture is confirmed by the laptop's posture client using a short-lived signed token that accompanies each request. Finance may also provide spending or contract limits for employees managing customer accounts.
- **Employees on internal engineering tools.** The most demanding use case is production deployment: The token carries employee identity and device trust, but the PDP must also confirm in real time that the engineer is on call by consulting PagerDuty. Here, caching is aggressive but short-lived: on-call status might be cached for minutes, while HR role data is refreshed daily.

These examples show why context is as important as policy. The correct set of signals, delivered in the right way and with the right freshness, makes authorization reliable. The wrong choices—stale tokens, unverifiable claims, or missing data—leave policies toothless. The rest of this chapter explores how organizations collect, deliver, and normalize trust signals so that policies can do their job.